Interne Audit Procedure

ISO 27001:2022 — Clause 9.2

Documentnummer	ISMS-021
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam CISO / Verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Deze procedure beschrijft hoe [Organisatienaam] interne audits van het ISMS plant, uitvoert en rapporteert. Interne audits controleren of het ISMS conform ISO 27001:2022 functioneert en effectief is.

2. Eisen (Clause 9.2)

Het interne auditprogramma:

- Wordt gepland met inachtneming van het belang van de betrokken processen en resultaten van voorgaande audits
- Definieert auditcriteria en scope voor elke audit
- Selecteert auditors die objectiviteit en onpartijdigheid waarborgen (auditors auditen niet hun eigen werk)
- Rapporteert resultaten aan het management

3. Auditprogramma

3.1 Jaarlijks auditprogramma

Alle clausules en relevante Annex A controls worden binnen een cyclus van 12 maanden geauditeerd:

Periode	Auditonderwerp	Clausules / Controls	Auditor
Q1	ISMS Governance & Documentatie	Clause 4, 5, 7.5	[Naam]
Q1	Risicomanagement	Clause 6.1, 8.2, 8.3	[Naam]
Q2	Personeel & Bewustwording	A.6.1-A.6.8, trainingsregistratie	[Naam]
Q2	Toegang & Authenticatie	A.5.15-A.5.18, A.8.2-A.8.5	[Naam]
Q3	Technische maatregelen	A.8.8, A.8.15, A.8.16, A.8.24	[Naam]
Q3	Incidentmanagement & Continuïteit	A.5.24-A.5.30	[Naam]
Q4	Fysieke beveiliging & Classificatie	A.7.1-A.7.7, A.5.12-A.5.13	[Naam]
Q4	Prestatiemonitoring & Verbetering	Clause 9.1, 9.3, 10.1, 10.2	[Naam]

3.2 Aanvullende audits

Ongeplande audits worden uitgevoerd na:

- Ernstige beveiligingsincidenten
- Significante organisatiewijzigingen
- Bevindingen die directe opvolging vereisen

4. Auditproces

4.1 Voorbereiding

Stap	Actie	Verantwoordelijke
1	Auditscope en -criteria vaststellen	CISO
2	Auditor(s) aanwijzen (onafhankelijk van geauditeerd gebied)	CISO
3	Auditchecklist opstellen op basis van clausules/controls	Auditor
4	Betrokken medewerkers informeren over planning	CISO
5	Relevante documentatie opvragen	Auditor

4.2 Uitvoering

Methode	Beschrijving
Documentreview	Controleer of beleid, procedures en registraties actueel en volledig zijn
Interviews	Bespreek met medewerkers of zij het beleid kennen en naleven

Observatie	Controleer of praktijk overeenkomt met beleid (bijv. clean desk, schermvergrendeling)
Technische controle	Controleer configuraties, toegangsrechten, patchstatus, logs
Steekproef	Neem willekeurige samples van registraties (bijv. toegangsverzoeken, incidentmeldingen)

4.3 Bevindingen classificeren

Classificatie	Beschrijving	Actie vereist
Major non-conformiteit	Systeemfalen: een clausule-eis wordt niet nageleefd of een control ontbreekt volledig	Correctieve maatregel met deadline, escalatie naar directie
Minor non-conformiteit	Gedeeltelijke naleving of incidenteel falen	Correctieve maatregel met deadline
Observatie	Geen non-conformiteit, maar verbetermogelijkheid geïdentificeerd	Aanbeveling, geen verplichte actie
Sterk punt	Goede praktijk die uitstijgt boven de norm-eis	Documenteren en delen

5. Rapportage

5.1 Auditrapport

Elk auditrapport bevat:

Onderdeel	Inhoud
Auditscope	Welke clausules/controls zijn geauditeerd
Auditcriteria	Tegen welke eisen is getoetst
Auditdatum en -duur	Wanneer en hoe lang
Auditor(s)	Wie heeft de audit uitgevoerd
Methoden	Documentreview, interviews, observatie, technisch
Bevindingen	Non-conformiteiten, observaties, sterke punten
Conclusie	Algehele beoordeling van het geauditeerde gebied
Correctieve maatregelen	Vereiste acties met eigenaar en deadline

5.2 Rapportage aan management

- Auditresultaten worden gerapporteerd aan de CISO en directie
- Samenvattende resultaten worden besproken in de managementreview
- Trend-analyse: vergelijking met voorgaande audits

6. Opvolging

- Eigenaren van non-conformiteiten voeren correctieve maatregelen uit binnen de deadline
- CISO verifieert de effectiviteit van de correctieve maatregelen
- Onopgeloste non-conformiteiten worden geëscaleerd naar directie

7. Auditchecklist (template)

#	Clausule / Control	Eis	Bevinding	Bewijs	Classificatie
1	Clause 4.3	ISMS scope is gedocumenteerd			
2	A.5.1	Informatiebeveiligingsbeleid is goedgekeurd en gecommuniceerd			
3	A.5.17	Wachtwoordbeleid wordt nageleefd			
4	Clause 6.1.2	Risicobeoordeling is uitgevoerd in afgelopen 12 maanden			
...	...	...			

8. Registraties

Registratie	Bewaartermijn
Auditprogramma	3 jaar
Auditrapporten	3 jaar
Correctieve maatregelen en opvolging	3 jaar
Auditchecklists	3 jaar

9. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]